Policy and legal track

What the law allows, and what would unlock more

Status: Draft v0.1 (2026-11-04), for Steve's review. Extension 5 of 10 (see the extensions overview). **Not legal advice.** This is a working map for planning; counsel must review it before any agreement is signed, and every citation should be checked against the current U.S. Code and OMB guidance.

Bottom line

Most of what this project needs is already lawful; it is slow, not forbidden. Public data needs no permission. Inspectors General can see their agency's records today. Treasury's Do Not Pay can match payments against death and exclusion data under the Payment Integrity Information Act. Cross-agency matching of people is allowed with a computer matching agreement, which takes months but is routine. The binding limits are narrower: tax data, the National Directory of New Hires, state-held benefit data, and the time it takes to sign agreements. Five legislative or policy changes would remove most of the delay; they are in section 6.

1. The laws that matter

Law or rule	What it does for this project	Constraint
Payment Integrity Information Act of 2019 (PIIA), 31 U.S.C. 3351-3358	Requires agencies to estimate and reduce improper payments; establishes the Do Not Pay initiative (3354) and the fraud risk and data analytics duties that replaced the Fraud Reduction and Data Analytics Act of 2015 (3357)	Do Not Pay matching is limited to the databases and uses the statute and OMB allow
OMB M-21-19 (Appendix C to Circular A-123)	How agencies measure improper payments and use Do Not Pay	Guidance, updated periodically; check for a newer memo
Privacy Act of 1974, 5 U.S.C. 552a	Governs federal records about individuals: systems of records notices, routine uses, disclosure limits	Applies to individuals, not businesses; sole proprietors are a grey area
Computer Matching and Privacy Protection Act of 1988 (amending the Privacy Act, 552a(o)-(u))	Allows matching of federal benefit and payroll records between agencies under a written matching agreement approved by each agency's Data Integrity Board	Agreements run 18 months plus a 12-month renewal; requires independent verification and notice before adverse action. PIIA lets Do Not Pay agreements run up to three years

Law or rule	What it does for this project	Constraint
Inspector General Act of 1978, 5 U.S.C. 401-424	IGs have access to all agency records and can subpoena others	Investigative matches by an IG are excepted from the matching rules
E-Government Act of 2002, section 208	Privacy impact assessments for new systems that hold personal data	Needed before any internal-data system goes live
26 U.S.C. 6103	Tax return confidentiality	Tax data can leave the IRS only in listed cases; work must sit inside IRS or TIGTA
42 U.S.C. 653 (National Directory of New Hires)	Employment and wage data used for child support	Access limited to listed programs; Do Not Pay has no general access
Social Security Act 205(r) and the Consolidated Appropriations Act, 2021	Gave Do Not Pay access to SSA's full death file for three years from December 2023	The access was time-limited; check whether it has been extended
False Claims Act, 31 U.S.C. 3729-3733	Civil liability (treble damages and penalties) for false claims; private relators can file qui tam suits	Lead packages should be written so DOJ can use them
Administrative False Claims Act (FY2025 NDAA, replacing the Program Fraud Civil Remedies Act)	Lets agencies pursue false claims up to $1M administratively	Agency must have set up the process; check implementation
Whistleblower protections, 5 U.S.C. 2302(b)(8) and 41 U.S.C. 4712	Protect federal employees and contractor or grantee employees who report fraud	Tip triage must flag these tipsters (see tip triage)
Paperwork Reduction Act, 44 U.S.C. 3501	Information collection from the public needs OMB approval	Applies if a pilot collects new data from the public; using existing records does not
Executive Order 14243 (March 2025), "Stopping Waste, Fraud, and Abuse by Eliminating Information Silos"	Directs agencies to give designated officials full access to unclassified records	Does not override statutes such as 6103 or the Privacy Act
Executive Order 14249 (March 2025), "Protecting America's Bank Account Against Fraud, Waste, and Abuse"	Directs Treasury to verify payments before disbursement, including through Do Not Pay	Implementation details in Treasury guidance
2026 anti-fraud task force order (the america.gov/fraud initiative)	Makes cross-agency fraud work a stated priority	Confirm the order's number and text before quoting it

2. What we can do today, by data type

Data	Route	Paperwork	Time
Public data (USAspending, SAM.gov, CMS files, SBA loan files, exclusion lists)	None needed	Terms of use	Now
Agency records about businesses	Program office data use agreement or OIG partnership	Data use agreement, security review	2-6 months

Data	Route	Paperwork	Time
Agency records about individuals, one agency	OIG partnership (IG Act) or routine use in the agency's system of records notice	Memorandum of understanding, privacy review	3-6 months
Matching individuals across agencies	Computer matching agreement, or Do Not Pay, or an IG investigative match	Agreement, Data Integrity Board approval, Federal Register notice	6-12 months
State-run program data (SNAP, UI, Medicaid)	State data sharing agreement; NASWA Integrity Data Hub for UI; T-MSIS through CMS for Medicaid	State agreement per state	3-9 months each
Tax data	Only inside IRS or TIGTA	—	—

3. The computer matching path, step by step

1. Identify the systems of records on both sides and confirm the match is a "matching program" (federal benefit or payroll records, automated comparison).
2. Draft the matching agreement: purpose, legal authority, justification and expected results (a cost-benefit analysis, which the ROI model supplies), records and fields, notice procedures, verification and due process, retention, security.
3. Data Integrity Board approval at each agency.
4. Report to OMB and Congress; publish the notice in the Federal Register at least 30 days before matching starts.
5. Independent verification of every hit, and notice with at least 30 days to contest, before any adverse action.

Ways to shorten it: run the first match as an IG investigative match; route through Do Not Pay, which already holds agreements and data; reuse an existing agreement's terms.

4. Privacy commitments we make in every proposal

- Minimum necessary fields; identifiers hashed across boundaries.
- Analysis inside the data owner's authorized environment.
- No adverse action on a model score; a person decides, with verification and notice.
- Model documentation and bias testing for every score.
- Publication only in aggregate, with small cells suppressed.

5. Risks to manage

- **Sole proprietors:** business records that are really records about individuals bring in the Privacy Act. Treat them as personal data.
- **Mission creep:** data shared for fraud detection must not be reused for other purposes without new authority.
- **Model error and disparate impact:** a screen that flags one community more than its real fraud rate warrants harms people and the case. Bias checks are part of release, not an afterthought.



- **Litigation holds and discovery:** leads may be discoverable; write them as factual reasons, not conclusions.

6. Legislative and policy changes that would unlock better data

Ranked by value for effort.

1. **Make Do Not Pay's access to SSA's full death file permanent** and extend it to state-administered programs. Single biggest win for payments to dead people (roadmap X-1).
2. **Give Do Not Pay access to the National Directory of New Hires** for benefit programs with income tests (UI, SNAP, SSI, Medicaid). Long proposed by Treasury and in past budget requests.
3. **Standing cross-agency analytics authority** like the Pandemic Response Accountability Committee's analytics center, but permanent and covering all programs, with the matching rules adapted (longer agreements, a single Data Integrity Board process).
4. **Require states to share eligibility and payment data for federally funded programs** with the federal program office and OIG in a standard format (T-MSIS-style for SNAP and UI).
5. **Payee bank account verification for every federal payment** before first disbursement (account-owner match), building on EO 14249.

7. Questions for Steve

1. Do we have counsel who has negotiated a computer matching agreement?
2. Should we write a short white paper on changes 1 and 2 for the task force now, since both have prior support?

